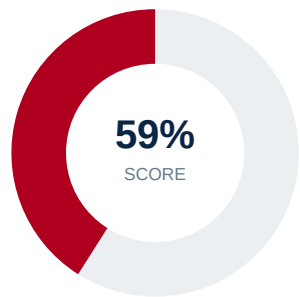


Security Audit Report

Web Application & Infrastructure Assessment



Target: <https://www.bridging-the-gap.com/data-mapping>
Prepared for: Client
Scan Date: 31 August 2026, 10:51
Overall Risk Status: **CRITICAL RISK**

Total Checks	Passed	Failed	Critical	High	Medium	Low
49	29	20	1	3	8	8

This report is confidential and intended solely for the addressed client. It summarizes automated findings from an external, black-box security scan and should be supplemented with manual penetration testing for a complete risk assessment.

1. Executive Summary

The assessment identified **20** issue(s) out of **49** checks performed, resulting in a security score of **59%** and an overall risk rating of **CRITICAL RISK**. There are **1 critical** and **3 high** severity finding(s) that should be prioritized for remediation.

2. SSL / TLS & Certificate Audit

Parameter	Result
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384
Hostname Verification	PASS
Self-Signed	NO
Valid From	Aug 29 18:45:38 2026 GMT
Valid Until	Nov 27 18:45:37 2026 GMT
Days Remaining	88
Issuer	countryName=US, organizationName=Let's Encrypt, commonName=YE2
Subject	commonName=www.bridging-the-gap.com
Subject Alt. Names (SAN)	www.bridging-the-gap.com

3. DNS, DNSSEC & Domain Audit

Parameter	Result
A Records	141.193.213.10, 141.193.213.11
AAAA Records	64:ff9b::8dc1:d50a, 64:ff9b::8dc1:d50b
MX Records	N/A
NS Records	N/A
CAA Records	None (finding)
DNSSEC Enabled	NO
WHOIS Registrar	Bluehost Inc.
Domain Expiration	2026-11-04 20:32:12+00:00
Days To Expiry	65

4. Security Issues & Recommendations

Severity	Check	Details	Recommendation
CRITICAL	Website Availability	Website returned HTTP 403.	Verify website availability and server configuration.
HIGH	HSTS	Strict-Transport-Security header is missing.	Configure a proper Strict-Transport-Security header.
HIGH	Content Security Policy	Content-Security-Policy header is missing.	Configure a proper Content-Security-Policy header.
HIGH	HTTP to HTTPS Redirect	HTTP does not correctly redirect to HTTPS.	Configure a permanent HTTP to HTTPS redirect.
MEDIUM	X-Content-Type-Options	X-Content-Type-Options header is missing.	Configure a proper X-Content-Type-Options header.
MEDIUM	X-Frame-Options	X-Frame-Options header is missing.	Configure a proper X-Frame-Options header.
MEDIUM	Referrer Policy	Referrer-Policy header is missing.	Configure a proper Referrer-Policy header.
MEDIUM	Permissions Policy	Permissions-Policy header is missing.	Configure a proper Permissions-Policy header.
MEDIUM	CSP Strength	No Content-Security-Policy header found.	Implement a restrictive Content-Security-Policy.
MEDIUM	HSTS Strength	HSTS header missing entirely.	Add a Strict-Transport-Security header.
MEDIUM	Clickjacking Protection	No X-Frame-Options or CSP frame-ancestors directive found - page can be framed.	Add X-Frame-Options: DENY/SAMEORIGIN or a CSP frame-ancestors directive.
MEDIUM	DNS - CAA Record	No CAA record found - any public CA can issue certs for this domain.	Add a CAA record restricting which Certificate Authorities may issue certificates.
LOW	Information Disclosure - server	Server technology information exposed: cloudflare	Remove unnecessary technology/version information from HTTP headers.
LOW	Cache-Control	Cache-Control header is missing.	Configure appropriate Cache-Control policies.
LOW	Security.txt (RFC 9116)	No security.txt file found.	Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
LOW	DNSSEC	DNSSEC does not appear to be enabled.	Enable DNSSEC at the domain registrar / DNS provider to protect against DNS spoofing.
LOW	Cross-Origin-Opener-Policy	Cross-Origin-Opener-Policy header is missing.	Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Resource-Policy	Cross-Origin-Resource-Policy header is missing.	Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Embedder-Policy	Cross-Origin-Embedder-Policy header is missing.	Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
LOW	X-Permitted-Cross-Domain-Policies	X-Permitted-Cross-Domain-Policies header is missing.	Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

5. Successful Security Checks

Check	Severity	Details
TLS Version	INFO	Secure TLS version detected: TLSv1.3
SSL Certificate	INFO	Valid TLS certificate was successfully retrieved.
TLS Cipher	INFO	Negotiated cipher: TLS_AES_256_GCM_SHA384
Certificate Hostname Match	INFO	Certificate hostname matches the requested domain (SAN/CN verified).
Legacy Protocol Support - TLSv1.0	INFO	Server correctly rejects TLSv1.0.
Legacy Protocol Support - TLSv1.1	INFO	Server correctly rejects TLSv1.1.
Protocol Support - TLSv1.2	INFO	Server supports TLSv1.2.
Protocol Support - TLSv1.3	INFO	Server supports TLSv1.3.
CORS Configuration	INFO	No permissive CORS wildcard detected.
Cookie Security	INFO	All detected cookies passed basic security attribute checks.
HTTP Methods	INFO	No explicit Allow header exposing methods.
Sensitive Path Exposure	INFO	No tested sensitive paths returned HTTP 200.
Mixed Content	INFO	No obvious HTTP resource references detected.
Subresource Integrity (SRI)	INFO	No external scripts missing SRI (or none detected).
Robots.txt	INFO	No robots.txt found (nothing to disclose).
HTTP Protocol Version	INFO	Negotiated protocol (via requests/urllib3): HTTP/1.1. Server advertises Alt-Svc: h3=":443"; ma=86400 (h3/h2 support).
Domain Expiry (WHOIS)	INFO	Domain registered until 2026-11-04 20:32:12+00:00 (65 days remaining).
Certificate Transparency Logs	INFO	Could not retrieve CT log data (crt.sh unavailable or rate-limited).
Version Disclosure	INFO	No specific software version numbers were disclosed in response headers.
HTTP TRACE Method	INFO	Server does not permit TRACE requests (HTTP 405).
Directory Listing	INFO	No directory listing detected on commonly probed paths.
Open Redirect	INFO	No open redirect behavior detected on commonly probed parameters.
Password Field Autocomplete	INFO	No password input fields detected on this page.
Exposed Secrets in Page Source	INFO	No obvious credential/key patterns detected in page source.
Cryptomining / Known Malicious Script Source	INFO	No script tags referencing known malicious/cryptomining domains were found.
Obfuscated Script / Hidden Iframe Patterns	INFO	No obfuscated script or hidden-iframe patterns detected in page source.
Unsolicited Cross-Domain Redirect	INFO	No meta-refresh redirect detected.
Self Signed Certificate	INFO	Certificate is not self-signed.
Certificate Expiry	INFO	Certificate has 88 days remaining.

6. Sensitive Path Enumeration

Path	HTTP Status	Risk	Exposed
.env	403	INFO	NO
.git/config	403	INFO	NO
config.json	403	INFO	NO
config.php	403	INFO	NO
debug	403	INFO	NO
actuator	403	INFO	NO
phpinfo.php	403	INFO	NO
server-status	403	INFO	NO
backup.zip	403	INFO	NO
backup.sql	403	INFO	NO
.DS_Store	403	INFO	NO
composer.json	403	INFO	NO
package-lock.json	403	INFO	NO
webpack.config.js	403	INFO	NO
docker-compose.yml	403	INFO	NO
database.sql	403	INFO	NO
dump.sql	403	INFO	NO
admin	403	INFO	NO
admin/	403	INFO	NO
debug.log	403	INFO	NO
error.log	403	INFO	NO
swagger.json	403	INFO	NO
swagger-ui.html	403	INFO	NO
graphql	403	INFO	NO
.htaccess	403	INFO	NO
wp-config.php	403	INFO	NO
.well-known/security.txt	403	INFO	NO
.git/HEAD	403	INFO	NO
.env.local	403	INFO	NO
.env.production	403	INFO	NO
.env.backup	403	INFO	NO
credentials.json	403	INFO	NO
secrets.yml	403	INFO	NO
secrets.yaml	403	INFO	NO
.aws/credentials	429	INFO	NO
id_rsa	429	INFO	NO
id_rsa.pub	429	INFO	NO
.npmrc	429	INFO	NO
.idea/workspace.xml	403	INFO	NO
.vscode/settings.json	429	INFO	NO
web.config	429	INFO	NO
vendor/composer/installed.json	429	INFO	NO
storage/logs/laravel.log	429	INFO	NO

Path	HTTP Status	Risk	Exposed
wp-content/debug.log	403	INFO	NO
.well-known/openid-configuration	429	INFO	NO
server.key	429	INFO	NO
server.pem	429	INFO	NO

7. Cookie Security

Cookie	Secure	HttpOnly	SameSite
__cf_bm	True	True	None

8. Prioritized Recommendations

1. Verify website availability and server configuration.
2. Configure a proper Strict-Transport-Security header.
3. Configure a proper Content-Security-Policy header.
4. Configure a proper X-Content-Type-Options header.
5. Configure a proper X-Frame-Options header.
6. Configure a proper Referrer-Policy header.
7. Configure a proper Permissions-Policy header.
8. Implement a restrictive Content-Security-Policy.
9. Add a Strict-Transport-Security header.
10. Add X-Frame-Options: DENY/SAMEORIGIN or a CSP frame-ancestors directive.
11. Remove unnecessary technology/version information from HTTP headers.
12. Configure a permanent HTTP to HTTPS redirect.
13. Configure appropriate Cache-Control policies.
14. Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
15. Add a CAA record restricting which Certificate Authorities may issue certificates.
16. Enable DNSSEC at the domain registrar / DNS provider to protect against DNS spoofing.
17. Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
18. Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
19. Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
20. Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

9. AI Overall Review & Suggestions

The security posture for bridging-the-gap.com is currently critical, with an overall score of 59% and a status flagged as CRITICAL_RISK. The most immediate concern is that the website is returning an HTTP 403 Forbidden error, meaning the site is effectively inaccessible to users and search engines. This availability issue masks other potential vulnerabilities but also represents a total loss of service. Beyond the outage, the site lacks fundamental security headers, leaving it exposed to common web attacks such as man-in-the-middle interception, clickjacking, and data leakage.

The most business-critical risks stem from the lack of HTTPS enforcement and the absence of security headers. Without a proper HTTP to HTTPS redirect and the Strict-Transport-Security (HSTS) header, users can be tricked into connecting over unencrypted channels, exposing sensitive data like login credentials or personal information. Additionally, the missing Content-Security-Policy (CSP) and X-Frame-Options headers leave the site vulnerable to cross-site scripting (XSS) and clickjacking attacks, where malicious actors could embed the site in a hidden frame to trick users into performing unintended actions. The lack of a DNS CAA record further weakens the domain's integrity by allowing any Certificate Authority to issue certificates, increasing the risk of mis-issued or fraudulent certificates.

To remediate these issues, the priority order should be: first, resolve the HTTP 403 error to restore site availability, as no other security measures are effective if the site is down. Second, implement the HTTP to HTTPS redirect and add the HSTS header to enforce secure connections. Third, deploy the Content-Security-Policy and X-Frame-Options headers to mitigate XSS and clickjacking risks. Finally, address the remaining medium-severity issues by adding X-Content-Type-Options, Referrer-Policy, and Permissions-Policy headers, and setting up a CAA record in DNS.

Quick wins include adding the missing security headers (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy), which are typically low-effort configuration changes in the web server or CDN settings but provide significant protection against common attacks. Implementing the HTTP to HTTPS redirect is also a straightforward fix that immediately improves security by ensuring all traffic is encrypted. These steps can be completed quickly and will significantly improve the site's security score and resilience.

Generated by TestPilot-AI Security Audit - automated scan results should be validated by a qualified security professional before remediation sign-off.